TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Maximum-severity GitLab CI/CD regex RCE is now exploited and in KEV

From **Cybersecurity Briefing - 2026-10-31** · 2026-10-30 to 2026-10-31 (global, US, industry; some items from 2026-10-28 and 2026-10-29 where primary reporting landed in the window). Indiana sections: 2026-10-26 to 2026-10-31. · Briefing generated 2026-10-31

REPORT ID	VERSION	HANDLING
CTI-20261102-02	1.0 · 2026-11-02 10:41 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-10-29	2026-11-02
CVES	**ANALYST**	
CVE-2026-97229 (CVSS 10.0)	Nick Sturgeon	

VULNERABILITY | CRITICAL | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

CVE-2026-97229 is an integer overflow (CWE-190) in the regular expression compiler that self-managed GitLab CE and EE use for CI/CD configuration. GitLab scores it CVSS 10.0 and says that, under certain conditions, an unauthenticated user can run code on the server with a crafted regex [S2] [S5]. GitLab fixed it on 2026-10-12 in 19.4.2, 19.3.5 and 19.2.8, and the CVE was published on 2026-10-13 [S2] [S5]. CISA added it to KEV on 2026-10-29 with a federal due date of 2026-11-01, which confirms the date the briefing could only infer [S3] [S4]. GitLab.com and GitLab Dedicated need no customer action [S5] [S12].

BleepingComputer reports that GitLab detected exploitation attempts [S1], and the only named target so far is Alpine Linux. An attacker registered a new account on its GitLab server on 2026-10-20 and sent crafted CI configurations through 2026-10-21, crashing workers eight times; in four of those crashes the exploit got partway and failed at the next step. The attacker also downloaded Alpine's GitLab container image, which Alpine reads as tuning the exploit to its build, and came back on 2026-10-25 and 2026-10-26 without success [S8]. Alpine found no evidence of code execution but could not rule it out, so it rebuilt the server, reset all passwords and replaced GitLab's secret keys [S8]. Nobody has publicly named the actor, and we found no published attacker IPs, domains, payload hashes or confirmed successful compromise [S8] [S13] [S14]. Public exploit material lowers the bar: Rapid7 published a proof of concept on 2026-10-13, and a Metasploit module was reportedly merged on 2026-10-30 [S11] [S13].

Three traps can leave a patched-looking server exposed. First, 19.3.4 is still vulnerable, and early reporting and at least one current write-up name it as the fix; GitLab now lists 19.3.5, and Alpine was attacked while

running 19.3.4 [S5] [S8] [S17]. Second, the fix is really a patch to Ruby's Onigmo regex engine that GitLab applies in its official packages. Source installs and custom images must also run Ruby 3.3.13, 3.4.12 or 4.0.9 or later, which is why Alpine was still vulnerable on GitLab 19.3.6 [S8] [S10] [S16]. Third, the versions named in the briefing do not fix CVE-2026-110264, a second CVSS 10.0 regex flaw fixed on 2026-10-21 in 19.5.1, 19.4.3, 19.3.6, 19.2.9 and older-branch backports [S6]. Shadowserver counted more than 1,000 servers still vulnerable to CVE-2026-97229 and more than 11,300 vulnerable to CVE-2026-110264 out of about 39,000 GitLab instances it sees daily, as reported on 2026-11-02 [S12].

What to do: move every self-managed instance to the newest patch on its branch rather than the minimum fix; GitLab's newest release page we reviewed lists 19.5.3, 19.4.5, 19.3.7 and 19.2.10 [S7]. Confirm the Ruby version that actually runs GitLab. Then hunt back to at least 2026-10-12 for anonymous CI lint requests, 502s paired with worker crashes, and new accounts followed by pushes to public projects [S9] [S13]. A clean web log is not proof of safety, because Alpine notes that a successful exploit leaves no crash and no web-log trace [S8]. If an exposed instance was unpatched during the window and compromise cannot be ruled out, treat it as compromised: rotate its secrets and rebuild [S8] [S13].

Key judgments

ALMOST CERTAIN · HIGH CONFIDENCE
Exploitation attempts against unpatched internet-facing GitLab servers will almost certainly continue through November 2026, given KEV listing, public exploit tooling, an EPSS percentile of about 98 and more than 1,000 servers still vulnerable. [S3] [S12] [S13] [S15]

LIKELY · MODERATE CONFIDENCE
A meaningful share of organizations that believe they patched are likely still exposed to this CVE or its sibling CVE-2026-110264, because of the 19.3.4 confusion, custom Ruby builds and the stop at the October 12 versions. [S5] [S6] [S8] [S12]

LIKELY · MODERATE CONFIDENCE
Some successful intrusions will likely go unnoticed by defenders who rely on web logs and crash counts alone, because a successful exploit may leave no crash or web-log trace and default log retention can be short. [S8] [S13]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE
There is a roughly even chance that a victim or vendor publicly confirms a successful compromise with theft of CI/CD secrets or repository data within 60 days. GitLab servers hold high-value credentials, but public evidence so far stops at attempted exploitation. [S8] [S12] [S13]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE
There is a roughly even chance that CVE-2026-110264 joins KEV within 30 days. It shares the same engine and attack surface class, but its EPSS is far lower and no exploitation has been publicly reported in the sources we opened. [S6] [S12] [S15] [S18]

INDICATORS OF COMPROMISE

No source we opened publishes attacker IPs, domains, payload hashes or malware names from in-the-wild activity, as ThreatDefence also stated on 2026-11-02 [S13]. Everything below is behavioral or artifact-based, drawn from GitLab, Rapid7, Alpine and secondary write-ups published 2026-10-12 to 2026-11-02; treat these as hunting leads rather than proof of compromise, and note that Rapid7 warns the undisclosed vendor path may differ from the demonstrated one [S9].

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`GET /api/v4/projects/<project>/ci/lint?content_ref=<commit>`	Lint route used in Rapid7's demonstrated attack path. It needs no credentials on a public project. Look for anonymous requests lasting several seconds or returning 502. Legitimate use exists, so it is a lead only.	REPORTED		[S9]
http-request	`POST /api/v4/ci/lint`	Attack route claimed by one secondary write-up with large unauthenticated request bodies. It conflicts with Rapid7's GET route on the project-scoped path. Low confidence; include only as a broad hunt.	REPORTED		[S17]
http-request	`GraphQL ciLint query with a hostile regular expression`	ThreatDefence says the bug can also be reached through GraphQL ciLint, and GitLab ships a detection named 'Graphql cilint hostile regexp'.	REPORTED		[S5] [S13]
http-request	`POST /api/graphql (body containing ciLint)`	/api/graphql is GitLab's standard GraphQL route, so a ciLint attempt should appear there. Inferred from the reported GraphQL path; no source publishes this exact request.	DERIVED		[S5] [S13]
http-request	`POST /users (new self-service registration shortly before CI pushes and lint requests)`	Alpine's attacker began by registering a new account, and the demonstrated attack needs push access to a public project. /users is the usual sign-up POST route; check your version. Inferred from those two reports.	DERIVED	2026-10-20	[S8] [S9]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`badgateway: failed to receive response: EOF`	Workhorse log message with HTTP 502 on a lint request lasting several seconds. Rapid7 says to correlate it with a Puma crash and the referenced commit. A 502 alone does not confirm exploitation.	REPORTED		[S9] [S19]
other	`Workhorse 502 whose correlation ID never appears in Rails logs`	Described by ThreatDefence as the strongest crash-based signal on lint or GraphQL routes.	REPORTED		[S13]
filename	`regexp_matcher.rb`	Appears in saved crash stack traces after an attempt. Not malicious by itself, since it is a GitLab source file.	REPORTED		[S9]
filename	`.gitlab-ci.yml (recent edits with extreme regex quantifiers)`	Default CI configuration file name. Rapid7 flags CI configuration and referenced commits with very large repetition counts, inline comments inside quantifiers or repeated POSIX character classes. The file name is inferred from GitLab's default; custom CI paths are possible.	DERIVED		[S9]
other	`Repository path of about 255 bytes ending in a non-ASCII or four-byte UTF-8 character`	Trigger path trait from public research. Matches GitLab's 'ci regexp oversized non ascii path' detection.	REPORTED		[S5] [S9] [S13]
other	`Workhorse request read_bytes near 2 MB`	Size marker for the attack carrier in Workhorse logs, per ThreatDefence's description of GitLab's rules. Not independently checked in the rule file.	REPORTED		[S13]
other	`Puma worker memory rise of about 2 GiB`	The worker needs a little over 2 GiB to run the demonstrated attack; a test instance needed about 9 GiB available. Low-memory hosts may see outages instead.	REPORTED		[S9]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`Unexpected shell, interpreter or network tool as a child of Puma, Ruby or Sidekiq, running as the git user`	Host indicator. Rapid7's test command ran as git (uid 998 on its test instance). One secondary write-up names gitlab-www instead, which conflicts with Rapid7 and is less credible.	REPORTED		[S9] [S13] [S17] [S18]
filepath	`/tmp (new files owned by git)`	Host indicator attributed to GitLab guidance via Censys in a secondary article. The Censys CVE-2026-97229 advisory we opened lists no host indicators, so treat this as second-hand.	REPORTED		[S18]
filepath	`/var/opt/gitlab/.ssh/authorized_keys`	Omnibus location to check for keys without the gitlab-shell prefix. A persistence hunting point, not a confirmed attacker action.	REPORTED		[S13] [S17]
filepath	`/opt/gitlab/embedded/service/gitlab-rails/public`	Check for new web-accessible files. A persistence hunting point, not a confirmed attacker action.	REPORTED		[S13]
filepath	`custom_hooks directories in Gitaly storage`	Check for new server hooks. A persistence hunting point; Alpine looked for unexpected hooks and found none.	REPORTED		[S8] [S13]
filepath	`/etc/gitlab/gitlab-secrets.json`	Holds GitLab secret keys. Treat as exposed on a confirmed or unexcluded compromise; check access if file auditing exists.	REPORTED		[S13] [S16]
filepath	`/var/log/gitlab/gitlab-workhorse/current`	Evidence source for 502s, durations and correlation IDs. Preserve before rotation.	REPORTED		[S9] [S13]
filepath	`/var/log/gitlab/gitlab-rails/api_json.log`	Evidence source for anonymous lint API requests. Preserve before rotation.	REPORTED		[S13] [S16]
filepath	`/var/log/gitlab/gitlab-rails/graphql_json.log`	Evidence source for ciLint GraphQL queries.	REPORTED		[S13]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`/var/log/gitlab/gitlab-rails/application_json.log`	Evidence source for CI regexp guard warnings and user creation.	REPORTED		[S13]
filepath	`/var/log/gitlab/puma/puma_stderr.log`	Evidence source for worker crashes and native [BUG] reports, including Onigmo frames.	REPORTED		[S13]
filepath	`/var/log/gitlab/sidekiq/current`	Evidence source for worker termination on the pipeline path.	REPORTED		[S13]
command	`journalctl -k`	Review kernel output for segfaults and out-of-memory events matching lint activity. This is a review step for defenders, not attacker activity.	REPORTED		[S13]
user-agent	`curl`	Scripted-client pattern in GitLab's 'ci lint scripted client error burst' rule as described by ThreatDefence. Not attacker-specific.	REPORTED		[S5] [S13]
user-agent	`wget`	As above. Not attacker-specific.	REPORTED		[S5] [S13]
user-agent	`python-requests`	As above. Not attacker-specific.	REPORTED		[S5] [S13]
user-agent	`python-urllib`	As above. Not attacker-specific.	REPORTED		[S5] [S13]
user-agent	`HTTPie`	As above. Not attacker-specific.	REPORTED		[S5] [S13]
user-agent	`(empty user agent)`	As above. Not attacker-specific.	REPORTED		[S5] [S13]
port	`8000/tcp outbound`	Default listener for the public proof-of-concept output, per ThreatDefence. Operator-configurable and weak. Review outbound traffic from the GitLab host.	REPORTED		[S13]
port	`80/tcp outbound`	Default for the Metasploit HTTP fetch payload, per ThreatDefence. Weak on its own; relevant only for GitLab processes reaching non-GitLab destinations.	REPORTED		[S13]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`GitLab detection: Onigmo native worker crash`	Named detection for self-managed customers. Also released for CVE-2026-110264.	REPORTED		[S5] [S6]
other	`GitLab detection: Graphql cilint hostile regexp`	Named detection for self-managed customers.	REPORTED		[S5]
other	`GitLab detection: ci regexp oversized non ascii path`	Named detection for self-managed customers.	REPORTED		[S5]
other	`GitLab detection: ci regexp guard rejection`	Named detection for self-managed customers.	REPORTED		[S5]
other	`GitLab detection: ci lint workhorse worker crash`	Named detection for self-managed customers.	REPORTED		[S5]
other	`GitLab detection: ci lint scripted client error burst`	Named detection for self-managed customers.	REPORTED		[S5]
other	`alpinelinux/gitlab:19.3.6 (pulled before 2026-10-27) and older tags`	Vulnerable container image rather than a malicious one. Alpine says images pulled before the 2026-10-27 rebuild lack the Ruby fix. Check for them in client environments.	REPORTED		[S8]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

GitLab has not published the 'certain conditions' behind its unauthenticated rating [S2] [S11]. Rapid7's demonstrated path works like this: an attacker with write access pushes a malicious CI configuration and a specially named path to a public project, then sends a credential-free request to the project's CI lint route that names that commit. A size check in Ruby's Onigmo compiler overflows, an oversized compiled pattern is accepted, and memory corruption in a Puma worker leads to commands running as the git account [S9] [S10]. No runner is involved, because the lint step is static and happens on the server [S9] [S16]. Open sign-up makes the write-access step easy, and Alpine's attacker followed that pattern by registering an account, sending crafted

CI configurations and pulling the target's container image [S8] [S13]. Failed attempts crash workers and return 502s, while a success may leave little trace [S8] [S13]. Post-exploitation steps below are hunting hypotheses unless marked as observed, since no successful intrusion has been publicly documented.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Reconnaissance	T1592.002 Gather Victim Host Information: Software	Observed at Alpine: the attacker downloaded the GitLab container image, which Alpine reads as tuning the exploit to its specific build. [S8]	Review container registry pulls by new or unknown accounts, especially of the image that runs GitLab itself.
Persistence	T1136 Create Account	Observed at Alpine: a newly registered account started the probing and sent crafted CI configurations. ATT&CK files this under Persistence, though here it served as attack setup. [S8] [S13]	Alert on new accounts that push to public projects or create projects soon after sign-up. Check application_json.log and audit_json.log.
Initial Access	T1190 Exploit Public-Facing Application	A crafted regex in a CI/CD configuration is processed by the vulnerable compiler, reached through CI lint, reportedly GraphQL ciLint, and a pushed pipeline file. Attempts observed at Alpine. [S2] [S8] [S9] [S13]	Correlate anonymous lint or ciLint requests with Workhorse 502s, Puma crashes and the referenced commit.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	Public research shows commands running as the git user from a Puma worker. Not confirmed in the wild. [S9] [S13]	Alert on shells or interpreters that are children of Puma, Ruby or Sidekiq under the git account. Baseline legitimate hooks and rake tasks first.
Command and Control	T1105 Ingress Tool Transfer	Reported for tooling only: Metasploit's documented example downloads a second stage from an attacker host. Not confirmed in the wild. [S13]	Review outbound connections from GitLab Ruby processes to non-GitLab destinations, and curl or wget started by git.

Tactic	Technique	Procedure observed	Detection opportunity
Persistence	T1098.004 Account Manipulation: SSH Authorized Keys	Hunting hypothesis: an unmanaged key added for the git user. Alpine checked for this and found none. [S8] [S13]	Check /var/opt/gitlab/.ssh/authorized_keys for entries without the gitlab-shell prefix.
Persistence	T1053.003 Scheduled Task/Job: Cron	Hunting hypothesis: changed crontab for the git user. [S13] [S18]	Review crontab changes for the git account using file integrity monitoring.
Persistence	T1505.003 Server Software Component: Web Shell	Hunting hypothesis: new files in the GitLab Rails public directory. [S13]	Compare /opt/gitlab/embedded/service/gitlab-rails/public with a clean package.
Credential Access	T1552.001 Unsecured Credentials: Credentials In Files	Potential impact per Alpine: 2FA secrets, CI/CD variables, runner tokens and integration credentials could be reached by code running on the server. Not observed. [S8] [S13] [S16]	Audit access to gitlab-secrets.json, and watch for abnormal use of runner, deploy and access tokens after the exposure window.
Collection	T1213.003 Data from Information Repositories: Code Repositories	Potential impact per Alpine: private repositories, confidential issues and merge requests could be read. Not observed. [S8]	Log and baseline outbound data volume and database connections from the GitLab host.
Initial Access	T1195.002 Supply Chain Compromise: Compromise Software Supply Chain	Downstream risk: a compromised server can schedule jobs on runners and alter code or releases. Alpine verified its repository, packages and releases and reported no tampering. [S8] [S13] [S16]	Compare protected branches, tags and artifacts against out-of-band copies. Review new runners, deploy keys and CI file changes.
Impact	T1499.004 Endpoint Denial of Service: Application or System Exploitation	Observed at Alpine as a side effect: eight worker crashes, 502 errors and failed CI jobs. Low-memory hosts or concurrent requests may disrupt service. [S8] [S9] [S19]	Alert on bursts of worker restarts, 502s and out-of-memory events in journalctl -k.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

Workhorse 502 on CI lint or GraphQL routes `SPLUNK SPL`

```
index=gitlab source="*/gitlab-workhorse/current*" status=502 (uri="*/ci/lint*" OR uri="/api/graphql*")
| stats count min(_time) as first_seen max(_time) as last_seen values(correlation_id) as
correlation_ids values(user_agent) as user_agents by client_ip, uri
| sort - count
```

Field names depend on your log parsing. Next, look up each correlation ID in Rails logs: IDs missing there are the stronger signal per ThreatDefence. Run from 2026-10-12, or 2026-10-01 if logs allow.

Anonymous GitLab CI lint API request `SIGMA`

```
title: Anonymous GitLab CI lint API request
status: experimental
description: Finds CI lint API calls with no authenticated user, a behavior reported for CVE-2026-97229
logsource:
  product: gitlab
  service: api_json
detection:
  selection:
    path|contains: '/ci/lint'
    username: null
  condition: selection
falsepositives:
  - Anonymous lint use on public projects, CI helper tools
level: high
tags:
  - attack.initial-access
  - attack.t1190
  - cve.2026-97229
```

Custom log source mapping required. For a stronger result, filter for long duration, 5xx status or a project with very recent pushes from a new account. Prefer GitLab's own TLDR rules where available.

Shell or tool spawned by a GitLab web or job worker `KQL`

```
DeviceProcessEvents
| where Timestamp > datetime(2026-10-12)
| where InitiatingProcessAccountName =~ "git"
| where InitiatingProcessFileName in~ ("ruby", "puma", "bundle") or InitiatingProcessCommandLine
has_any ("puma", "sidekiq")
| where FileName in~ ("sh", "bash", "dash", "curl", "wget", "python", "python3", "perl", "nc", "ncat",
"socat")
| project Timestamp, DeviceName, InitiatingProcessCommandLine, FileName, ProcessCommandLine
| sort by Timestamp desc
```

Needs an EDR agent on the GitLab host and tuning, because GitLab hooks and maintenance tasks can legitimately start child processes. Native crash paths may leave no shell if an attacker works in memory.

Onigmo and regex crash traces in worker logs `SPLUNK SPL`

```
index=gitlab (source="*/puma/puma_stderr.log*" OR source="*/sidekiq/current*") ("[BUG]" OR "Onigmo" OR
"regexp_matcher.rb")
| timechart span=1h count by host
```

Alpine saw eight crashes across two days, so a low count still matters. Match the times against lint requests, new accounts and pushes.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
GitLab CE/EE (self-managed), CVE-2026-97229	19.2 before 19.2.8; 19.3 before 19.3.5 (19.3.4 is vulnerable); 19.4 before 19.4.2	19.2.8, 19.3.5, 19.4.2 for this CVE; prefer 19.2.10, 19.3.7, 19.4.5 or 19.5.3 or later	CVE-2026-97229	10.0	0.273 (98.06th percentile, 2026-11-02)	Yes (added 2026-10-29)	2026-11-01
GitLab CE/EE (self-managed), sibling flaw CVE-2026-110264	7.0 before 18.11.13; 19.0 before 19.0.10; 19.1 before 19.1.9; 19.2 before 19.2.9; 19.3 before 19.3.6; 19.4 before 19.4.3; 19.5 before 19.5.1	18.11.13, 19.0.10, 19.1.9, 19.2.9, 19.3.6, 19.4.3, 19.5.1 or later	CVE-2026-110264	10.0	0.01349 (71.48th percentile, 2026-11-02)	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Ruby under source-built or custom-image GitLab	Ruby builds without the Onigmo fixes, including custom GitLab images such as alpinelinux/gitlab images pulled before 2026-10-27	Ruby 3.3.13, 3.4.12, 4.0.9 or later (all four related fixes); GitLab's official packages carry their own patched Ruby	CVE-2026-97229, CVE-2026-110264, CVE-2026-93577, CVE-2026-89078 (GitLab-assigned)	See GitLab CVE entries	N/A	No	N/A

Immediate (0–24 hours)

- Find every self-managed GitLab instance, including lab, forgotten and client-hosted servers, and record its version, install type and internet exposure. `IT OPS` [S3] [S13]
- Upgrade each instance to the newest patch on its branch: 19.5.3, 19.4.5, 19.3.7 or 19.2.10 as listed by GitLab, or later. Do not stop at 19.3.4 or at the October 12 versions. Back up and copy gitlab-secrets.json off the host first, and plan for downtime on single-node installs. `IT OPS` [S5] [S6] [S7] [S16]
- Confirm the Ruby version actually running GitLab on source and custom-image installs. Require Ruby 3.3.13, 3.4.12 or 4.0.9 or later, then restart all Puma and Sidekiq processes. `IT OPS` [S8] [S10] [S16]
- Preserve Workhorse, Rails, Puma and Sidekiq logs plus journald data before rotation deletes them; default retention may not cover the exposure window. `SOC` [S8] [S13]
- Hunt from 2026-10-12 (or 2026-10-01 if logs allow) for anonymous lint and ciLint requests, 502s with worker crashes, new accounts followed by pushes, suspicious CI regexes and git-user child processes. `SOC` [S9] [S13]
- Enable GitLab's six named detections for this CVE from its TLDR repository (release 0.2.0 lists CVE-2026-97229 coverage). These detections alert but do not prevent attacks. `SOC` [S5] [S18] [S21]
- Decide and document how to handle any exposed instance that was unpatched during the window. Alpine's example is to treat it as compromised when success cannot be excluded. `LEADERSHIP` [S3] [S8]

Short term (1–7 days)

- On instances where compromise cannot be excluded, rebuild from clean media, then rotate runner tokens, CI/CD variables, access tokens, deploy keys, integration and webhook credentials, push mirror credentials

and user passwords, and replace GitLab secret keys. `IT OPS` [S8] [S13] [S16]
- Review new admins, recent accounts, tokens, runners, deploy keys, server hooks, cron entries, SSH keys and new web files. `SOC` [S13] [S16]
- Compare protected branches, tags, packages and release artifacts against out-of-band copies, as Alpine did, and record the result. `SOC` [S8] [S13]
- Disable open sign-up or require admin approval, and review the need for public projects on each instance. `IT OPS` [S13] [S16]
- Limit instance runners to specific groups or projects, mark deployment runners as protected, disable untagged jobs and keep privileged executors away from untrusted projects. `IT OPS` [S16]
- If your patching tools record only the GitLab version, add a check for the running Ruby version to their compliance reports for custom builds. `IT OPS` [S8] [S16]

Long term

- Set a one-day patch target for critical GitLab releases and check each release for Ruby or other component patches your build must apply, the change Alpine adopted. `LEADERSHIP` [S8]
- Keep GitLab logs longer than 14 days in a central store, and log outbound and database connections from the server. `SOC` [S8] [S16]
- Keep release evidence such as signed tags, SBOMs and provenance outside the GitLab server, and do not store signing keys on it. `IT OPS` [S8] [S16]
- Move self-managed source-code platforms behind VPN or identity-aware access unless public access is a business need, and review that exception yearly. `LEADERSHIP` [S11] [S20]
- Review in-house Ruby applications for regexes compiled from untrusted input, using Regexp.new, Regexp.union, Regexp.compile or interpolation, and keep Ruby current. Ruby says timeouts and length limits do not reliably prevent these bugs. `IT OPS` [S10]

Workarounds & compensating controls

- If patching is delayed, restrict inbound access to the GitLab web interface to trusted networks. Censys recommends this as the fallback. `IT OPS` [S11]
- At a proxy or WAF, block credential-free access to CI lint and GraphQL ciLint routes. This does not fix the compiler and does not cover the pipeline path or CVE-2026-110264. `IT OPS` [S9] [S13]
- Restrict public project creation and credential-free access to public projects attackers can write to. Rapid7 and ThreatDefence describe this as a temporary measure only. `IT OPS` [S9] [S13]
- Limit outbound traffic from the GitLab host to approved destinations to slow second-stage download and data theft. GitLab itself lists no workaround for this CVE, so treat this as defense in depth. `IT OPS` [S5] [S13]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] BleepingComputer: Hackers now exploiting max severity GitLab flaw in attacks
Published 2026-10-30 · **B1** Usually reliable, confirmed by other sources
Briefing source. Reports KEV listing, GitLab's exploitation attempts statement and Shadowserver's count of nearly 2,800 exposed CE instances.

[S2] CVE Program / GitLab CNA: CVE record CVE-2026-97229
Published 2026-10-13 · **A1** Completely reliable, confirmed by other sources
Primary. Updated 2026-10-30; includes CVSS, CWE, ranges, SSVC and references.

[S3] CISA: Known Exploited Vulnerabilities catalog, version 2026.10.30
Published 2026-10-30 · **A1** Completely reliable, confirmed by other sources
Primary. Date added 2026-10-29, due 2026-11-01, ransomware use Unknown. We read the newest part of this date-sorted file only; CVE-2026-110264 was not in that part.

[S4] CISA: CISA Adds Two Known Exploited Vulnerabilities to Catalog
Published 2026-10-29 · **A1** Completely reliable, confirmed by other sources
Primary. Also lists Cisco CVE-2026-76418 and describes BOD 26-04.

[S5] GitLab: GitLab Critical Patch Release: 19.4.2, 19.3.5, 19.2.8
Published 2026-10-12 · **A1** Completely reliable, confirmed by other sources
Primary vendor advisory. Lists detections and no workaround. A search index still showed a title naming 19.3.4, which suggests the page changed.

[S6] GitLab: GitLab Critical Patch Release: 19.5.1, 19.4.3, 19.3.6, 19.2.9, 19.1.9, 19.0.10, 18.11.13
Published 2026-10-21 · **A1** Completely reliable, confirmed by other sources
Primary. Sibling flaw CVE-2026-110264.

[S7] GitLab: GitLab Patch Release: 19.5.3 and backports
Published · **A2** Completely reliable, probably true
Primary. Newest release reviewed; the page gave no publication date. Later releases may exist.

[S8] Alpine Linux: GitLab security incident (CVE-2026-97229)
Published 2026-10-28 · **A2** Completely reliable, probably true
Primary victim report, updated 2026-10-30. Only named in-the-wild case found.

[S9] Rapid7: GitLab CI/CD regex integer overflow technical analysis (CVE-2026-97229)
Published 2026-10-16 · **A2** Completely reliable, probably true
Original researcher. Demonstrated path needs write access, which conflicts with PR:N; Rapid7 warns the private report's path may differ.

[S10] Ruby core team: Regexp fixes for GitLab CVEs
Published 2026-10-23 · **A1** Completely reliable, confirmed by other sources
Primary. Maps GitLab CVEs to Ruby fixes; also copied to oss-security.

[S11] Censys: CVE-2026-97229 advisory
Published 2026-10-13 · **B2** Usually reliable, probably true
Exposure at disclosure: 25,766 hosts of 82,454 and 79,224 web properties of 205,541. Pre-dates KEV listing.

[S12] BleepingComputer: Over 1,000 GitLab servers vulnerable to ongoing RCE attacks
Published 2026-11-02 · **B2** Usually reliable, probably true
Newest reporting found. Relays Shadowserver counts.

[S13] ThreatDefence: GitLab CVE-2026-97229 Exploited: Hunting and Patching
Published 2026-10-31 · **C2** Fairly reliable, probably true
Detailed hunting guide, updated 2026-11-02, with cited primaries. Rule details and Metasploit facts are its description; we did not open the module or the individual rule files.

[S14] The Hacker News: CISA adds actively exploited GitLab RCE
Published 2026-10-30 · **B1** Usually reliable, confirmed by other sources
Corroborates KEV listing and Alpine details; no indicators.

[S15] FIRST: EPSS API: CVE-2026-97229 and CVE-2026-110264
Published 2026-11-02 · **A2** Completely reliable, probably true
Model output, not evidence of attacks.

[S16] Safeguard: GitLab CVE-2026-97229: Patch Self-Hosted GitLab, Check the Ruby Underneath, and Review CI Runner Exposure
Published 2026-11-01 · **C2** Fairly reliable, probably true
Vendor blog with product promotion; technical guidance agrees with primaries.

[S17] Decryption Digest: GitLab CVE-2026-97229: CVSS 10.0 Unauthenticated RCE
Published 2026-10-30 · **C4** Fairly reliable, doubtful
Conflicts with primaries on 19.3.4, 19.1 impact, route, service account and ransomware use. Used only to record those disputes.

[S18] CISO Platform: GitLab CVE-2026-97229 Exploited: CI/CD RCE Added to CISA KEV
Published 2026-11-01 · **C3** Fairly reliable, possibly true
Secondary. Relays host indicators attributed to GitLab guidance via Censys and sibling CVE status.

[S19] Cyber Security News: PoC Exploit Released for Critical GitLab RCE Vulnerability (CVE-2026-97229)
Published 2026-10-16 · `C2` Fairly reliable, probably true
Secondary summary of Rapid7's work. Notes that a 502 alone is not proof.

[S20] The Back Room Tech: CISA warns GitLab critical vulnerability is actively exploited in attacks
Published · `C3` Fairly reliable, possibly true
Secondary. Page shows no explicit date; sources retrieved 2026-11-01. Suggests VPN placement.

[S21] GitLab Security: TLDR detection repository changelog, release 0.2.0
Published 2026-10-30 · `A2` Completely reliable, probably true
Primary. Confirms detections for CVE-2026-97229. Maintainers list known issues with some legacy rules, so test before relying on them.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-09-24	CVE ID reserved.	[S2]
2026-10-12	GitLab releases fixes in 19.4.2, 19.3.5 and 19.2.8.	[S5]
2026-10-13	CVE published. Rapid7 proof of concept released. Censys reports no known exploitation and 25,766 vulnerable hosts. Alpine mistakenly upgrades to 19.3.4.	[S2] [S8] [S11]
2026-10-16	Rapid7 publishes technical analysis.	[S9]
2026-10-20	Attacker registers a new account on Alpine's GitLab and begins probing; main attack runs through 2026-10-21.	[S8]
2026-10-21	GitLab releases fixes for sibling flaw CVE-2026-110264.	[S6]
2026-10-22	Alpine upgrades to 19.3.6, which does not fix its custom image.	[S8]
2026-10-23	Ruby 4.0.9, 3.4.12 and 3.3.13 released. Alpine blocks the attacker's account.	[S8] [S10]

Date	Event	Source
2026-10-25	Attacker returns to Alpine's GitLab through 2026-10-26; attempts fail.	[S8]
2026-10-26	Alpine finds its instance still vulnerable after the upgrade.	[S8]
2026-10-28	Alpine completes its rebuild and resets all passwords; its incident post is dated this day.	[S8] [S13]
2026-10-29	CISA adds CVE-2026-97229 to KEV. Alpine reopens on 19.3.7.	[S3] [S4] [S8]
2026-10-30	BleepingComputer reports exploitation. GitLab TLDR release 0.2.0 adds CVE detections. Metasploit module reportedly merged.	[S1] [S13] [S21]
2026-11-01	Federal KEV due date.	[S3]
2026-11-02	BleepingComputer reports more than 1,000 servers still vulnerable, per Shadowserver.	[S12]

Relevance to Indianapolis, Indiana & managed clients

We found no reporting of Indiana victims and no state-level exposure figures, so local impact is unmeasured rather than absent. The realistic Indiana exposure is any self-hosted GitLab server: manufacturers and software teams keeping source code and OT or product build pipelines in-house, universities and K-12 groups with open sign-up or public projects, hospitals and health IT vendors with integration code and deployment credentials, and state and local agencies or their contractors. Federal BOD 26-04 deadlines do not bind state, local or private organizations, though CISA encourages all organizations to prioritize these flaws, so treat 2026-11-01 as a benchmark that has already passed. Small and mid-size firms are at higher risk from a forgotten GitLab server, a custom Docker image or a shared runner with cloud credentials. Managed service clients should get a fleet check for GitLab version, Ruby version, open sign-up and internet exposure, and a compromise review where the server was exposed and unpatched after 2026-10-12. Any confirmed theft of client data or credentials may also trigger contract notice duties and Indiana breach notification review, which should go to counsel.

Intelligence gaps

- GitLab has not published the 'certain conditions' or how an attacker reaches this flaw without credentials; Rapid7's path requires write access and may differ from the private HackerOne reports.
- No actor, motive, attacker infrastructure, payload or hash is public. Alpine published no IP addresses or account names.
- No successful in-the-wild compromise has been publicly confirmed. Watch for KEV ransomware field changes, which currently read Unknown.
- The evidence behind CISA's listing and GitLab's statement of exploitation attempts is not public beyond the Alpine case; it is unclear whether these describe the same activity.
- Whether CVE-2026-110264 is exploited: it did not appear in the newest part of KEV catalog 2026.10.30 that we read, and later catalog versions were not checked.

- Shadowserver's 2,800 figure (exposed CE, 2026-10-30), its 1,000-plus figure (vulnerable, 2026-11-02) and Censys's 25,766 figure (2026-10-13) use different scopes and methods, so they do not form a patching trend.
- The newest GitLab release may be later than the 19.5.3 page reviewed, and that page has no date; check GitLab's release list before upgrading.
- We did not open the Metasploit pull request or proof-of-concept repository, by policy. Claims about them rest on the CVE record, Censys and ThreatDefence.
- We could not retrieve NVD's page or the CISA BOD 26-04 text directly; directive details come from the CISA alert and KEV entry.

Other notes

- Corrections to the briefing: the 2026-11-01 federal deadline is stated in the KEV catalog, and the KEV date and CISA alert were checked directly. The briefing's fix versions are right for this CVE but incomplete given CVE-2026-110264.
- The fix-version dispute: some sources say 19.3.4. GitLab's advisory now says 19.3.5, Alpine describes 19.3.4 as lacking the fix, and Safeguard says it remains vulnerable. We follow GitLab and treat 19.3.4 as vulnerable [S5] [S8] [S16].
- Other disputes in lower-quality reporting: Decryption Digest claims 'known ransomware use' in the KEV entry, while the catalog says Unknown [S3] [S17]. It also lists 19.1 as affected, a POST route and the gitlab-www account; GitLab and Rapid7 say 19.2 to 19.4, a GET project route and the git account [S5] [S9] [S17]. BleepingComputer notes one of the six GitLab KEV entries has been tied to ransomware, without saying it is this one [S12].
- Rating versus demonstration: GitLab and CISA describe this as unauthenticated, while the public demonstration needs write access to a public project first. Instances with open sign-up should be seen as effectively exposed to anyone [S2] [S9] [S13].
- Ruby has not requested its own CVE IDs for these fixes, so scanners may not flag a vulnerable Ruby under Ruby's name; track them through the GitLab IDs [S10].
- The fix for CVE-2026-97229 shares Ruby change #19020 with CVE-2026-93577, fixed one GitLab release earlier in 19.4.1. ThreatDefence describes the later CVE as a bypass of that incomplete fix [S10] [S13].
- CISA's listing paired this flaw with Cisco CVE-2026-76418, an unrelated ASA and FTD denial-of-service issue [S4] [S14].
- The KEV entry calls for BOD 26-04 compliance and points to CISA's forensic triage requirements, which suits a server where patching alone cannot show the host was clean before the fix [S3] [S4].
- GitLab's own TLDR changelog lists known issues with some older rules, so test the rules against your logs before relying on them [S21].

CTI-20261102-02 v1.0 · Generated 2026-11-02 10:41 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.